

CHT Platform — Auth Decoupling & Cognito Migration Report

Community Health Technologies (CHT) Platform Tool

Report date: June 3, 2026 (revised)

Prepared for: Internal stakeholders — compliance, engineering, product leadership, and MediaHub team

Scope: CHT-owned IdP (Amazon Cognito), MediaHub GoTrue decommission for end users, admin-only MediaHub access, and API-key-based server-to-server integration

Related: [CHT-MediaHub-Unified-Go-Forward-Report.md](./CHT-MediaHub-Unified-Go-Forward-Report.md) | [CHT-MediaHub-Go-Forward-Options.md](./CHT-MediaHub-Go-Forward-Options.md)

Strategy: Option 3 selected — this auth/Cognito workstream is **Phase 1 (immediate)** and proceeds independently of MediaHub microservices recovery (months 4–8).

1. Executive Summary

CHT’s **approved auth strategy** is to **own the identity provider** by migrating from MediaHub-hosted GoTrue/Supabase to **Amazon Cognito** (one user pool per environment, required TOTP MFA). **KOL, HCP, and industry users will never authenticate through or access MediaHub.** All end-user login, signup, OAuth, and sessions happen on CHT only.

MediaHub’s role after migration:

Capability	End users (KOL/HCP/industry)	CHT admins	Integration
Authentication (GoTrue)	Removed — no auth users on MediaHub	Admin-only GoTrue (or separate admin auth) until MediaHub decommissions non-admin IdP	MediaHub decommissions GoTrue for all non-admin users
Content / HCP data APIs	No direct access — data served via CHT APIs	May use MediaHub admin UI for content ops	API key retained — server-to-server only (MEDIAHUB_API_KEY)

MediaHub will **no longer receive CHT auth users** as it does today (shared GoTrue, shared JWT secret, OAuth redirects to mediahub.communityhealth.media). Identity leaves MediaHub entirely for end users. MediaHub keeps **API-key-based integration** for catalog ingestion, HCP upsert, and playlist sync — initiated by the CHT backend, not by user sessions on MediaHub.

Status: Planned, not started. Production still uses GoTrue via MediaHub. Cognito Terraform, migration runbook, and MediaHub GoTrue decommission plan are not yet in the repository.

The immediate next step: Produce and sign off a **Cognito Migration & MediaHub Auth Decommission Specification** covering Cognito architecture, user migration, MediaHub coordination (GoTrue shutdown for non-admins), API contracts, and cutover/rollback.

2. Strategic Context

2.1 Approved principles

Principle	Policy
IdP ownership	CHT owns IdP — Amazon Cognito with MFA
User-facing product	CHT only — login, signup, catalog, sessions, payments, surveys
End-user roles	KOL, HCP, industry — no MediaHub UI, GoTrue, links, or credentials
Admin access	Only CHT admins may access MediaHub (content/KOL workflows)
MediaHub auth users	Decommission GoTrue for all non-admin users — MediaHub stops being an auth destination for CHT learners
Data exchange	API key only — server-to-server (CHT backend ↔ MediaHub API); end users never call MediaHub

2.2 Why CHT must own the IdP

Concern	Today (MediaHub GoTrue)	After Cognito
IdP ownership	MediaHub hosts GoTrue; shared JWT secret	CHT-owned Cognito pools per environment
MFA	Not enforced	Required TOTP MFA
User perception	OAuth may redirect through MediaHub hostname	CHT domain only for end users
SOC 2 / enterprise	Cannot evidence IdP control	CHT controls access governance and audit evidence
MediaHub auth coupling	CHT users exist as GoTrue users on MediaHub	No end-user auth records on MediaHub

2.3 MediaHub coordination (required)

MediaHub team actions needed as part of this program:

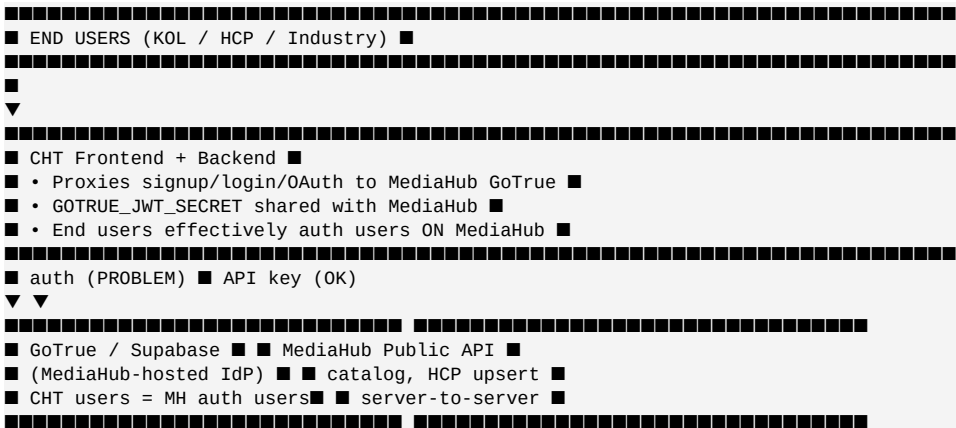
1. **Decommission GoTrue for non-admin users** — remove CHT learner/HCP/KOL/industry accounts from shared auth; stop accepting CHT OAuth redirect traffic for end users.
2. **Retain admin GoTrue access** (interim) or migrate MediaHub admin auth separately — only staff who manage content in MediaHub UI.
3. **Retain public/content API** with API key — CHT backend continues MediaHubService and MediaHubSyncService server-to-server.
4. **No user-session or JWT-based auth to MediaHub** from CHT end users post-cutover.

2.4 Relationship to other MediaHub dependencies

Area	Current state	Target state
Authentication (IdP)	MediaHub GoTrue/Supabase	Amazon Cognito (CHT-owned); MediaHub GoTrue decommissioned for end users
Conversation playlists	Live MediaHub API	CHT APIs ; ingest/sync via API key
KOL/content/catalog	MediaHub API + admin UI	End users → CHT; admins → MediaHub UI optional; data via API key
HCP sync on signup	MediaHub /hcp/upsert	Keep — server-to-server API key only
Podcasts	Direct YouTube API	Keep — no MediaHub

3. Current State

3.1 Architecture today (problem)



Problem: CHT end users are **auth users on MediaHub**. OAuth redirects hit mediahub.communityhealth.media. This must end.

3.2 Layer inventory

Layer	Today	Issue
IdP	MediaHub GoTrue/Supabase	CHT does not own IdP; users registered on MediaHub
Login flows	CHT proxies to GoTrue	Must move to Cognito
JWT validation	GOTRUE_JWT_SECRET (HS256)	Replace with Cognito JWKS (RS256)
Sessions	CHT Postgres + httpOnly cookies	Keep — unchanged
User.authId	GoTrue sub	Remap to Cognito sub on migration
Catalog / HCP	MediaHub API key (server-side)	Keep — API key model is correct
Chatbot	GoTrue JWT in session	Switch to Cognito access token via backend

3.3 Code touchpoints

Component	Location	Migration action
GoTrue strategy	backend/src/auth/gottrue.strategy.ts	Replace with Cognito JWKS strategy
JWKS strategy (Auth0 scaffold)	backend/src/auth/jwt.strategy.ts	Adapt for Cognito issuer/audience
Auth controller (GoTrue proxy)	backend/src/auth/auth.controller.ts	Rewire to Cognito SignUp/InitiateAuth/OAuth
Auth module factory	backend/src/auth/auth.module.ts	Select Cognito strategy
OAuth URL builder	frontend/src/lib/supabase-oauth.ts	Remove — Cognito Hosted UI or Amplify on CHT domain
Catalog / HCP sync	mediahub.service.ts, mediahub-sync.service.ts	Keep — API key only
Terraform secrets	secrets-manager/	Add Cognito pool/client; remove GoTrue secrets post-cutover

4. Target State

4.1 Access boundary

Actor	CHT app	Cognito (CHT-owned)	MediaHub UI	MediaHub API (key)
HCP / KOL / Industry	Yes	Yes (via CHT only)	No	No
CHT admin	Yes	Yes	Yes (content ops)	Via CHT backend
CHT backend	N/A	Validates JWT	N/A	Yes (API key)

4.2 Target architecture

[illegible]

4.3 Cognito requirements

Requirement	Target
IdP	Amazon Cognito — one user pool per environment
MFA	Required TOTP MFA
OAuth	Google (and Apple if required) via Cognito
JWT	RS256 via Cognito JWKS
Sessions	Existing CHT Postgres session + httpOnly cookies
Custom attributes	NPI, profession, institution (today in GoTrue user_metadata)

4.4 Auth flows — target behavior

Flow	Target
Email/password signup	CHT UI → backend → Cognito SignUp → CHT session
Email/password login	CHT UI → backend → Cognito InitiateAuth (+ MFA) → CHT session
Google OAuth	Cognito federated identity — CHT domain only
Password reset	Cognito ForgotPassword — CHT-branded emails
Admin login	Cognito + @Roles(ADMIN) in Postgres
Chatbot	Cognito access token via CHT backend — never MediaHub JWT

4.5 MediaHub API integration (unchanged model, clarified scope)

Direction	Auth method	Notes
CHT → MediaHub (HCP upsert, catalog fetch)	API key (MEDIAHUB_API_KEY)	Server-to-server; no user identity passed as MediaHub auth user
CHT → End user (catalog, playlists)	CHT session / Cognito	MediaHub never in user path
End user → MediaHub	Blocked	No URLs, keys, or GoTrue accounts
MediaHub admin UI	Admin credentials only	Separate from CHT learner auth population

Important: MediaHub keeps the API key for **integration safety and access control** on server-to-server calls. It does **not** receive CHT end-user auth sessions or GoTrue user records after cutover.

5. Immediate Next Step (0–30 Days)

5.1 Deliverable

Cognito Migration & MediaHub Auth Decommission Specification — signed off by CHT engineering, product, compliance, and MediaHub team.

5.2 Required decisions

Cognito architecture

- User pool per environment: platform, staging, dev
- App clients (SPA + backend confidential client if needed)
- Hosted UI vs custom CHT login pages
- Custom attributes for NPI, profession, institution
- MFA policy: TOTP required for all users; grace period?

User migration

- Import GoTrue users into Cognito vs. force re-registration / password reset?
- Map `user.authId` from GoTrue `sub` to Cognito `sub` (migration table, email linking)
- Cutover: big-bang vs. staging-first; parallel JWT acceptance window?

MediaHub decommission (coordination)

- Date MediaHub disables GoTrue for CHT end-user OAuth redirect URLs
- Process to remove/deactivate non-admin GoTrue user records for CHT
- Admin-only GoTrue retention plan on MediaHub side (interim or permanent)
- Confirm API key remains valid for CHT backend post-auth cutover
- Single point of contact and rollback if MediaHub decommission precedes Cognito readiness

API integration

- Catalog: live proxy vs. sync-to-CHT-DB (recommend sync)
- HCP upsert: confirm no auth-user coupling in MediaHub API (key-only)
- Playlist/KOL metadata ingestion schedule

Compliance

- Subprocessor register: remove GoTrue as CHT auth provider; list Cognito; MediaHub as content API subprocessor only
- Privacy policy: auth provided by CHT via Cognito

Ownership

Role	Responsibility
CHT engineering lead	Cognito implementation, user migration, cutover
CHT infra / Terraform	Cognito pools, secrets, ECS env vars
MediaHub liaison	GoTrue decommission for non-admins ; API key continuity; admin access
Product	User communication for re-login / MFA enrollment
Compliance	Subprocessor register, access-governance evidence

6. Implementation Sequence

6.1 Phased roadmap

Phase	Duration	Work
Planning (now)	1–2 weeks	Cognito + MediaHub decommission spec; user migration plan
Build	3–5 weeks	Cognito Terraform; backend Cognito strategy; frontend auth swap
Staging	1–2 weeks	Staging pool; MFA; OAuth; no MediaHub auth paths
MediaHub coordination	Parallel	Decommission GoTrue for non-admins on agreed date
Production cutover	1 week	User migration; remove GoTrue secrets; monitor
Hardening	Ongoing	Auth tests in CI; catalog API sync expansion

6.2 Dependency order

1. Sign off Cognito Migration & MediaHub Auth Decommission spec
 -
 - 2a. Terraform: Cognito pools + MFA + app clients
 -
 - 2b. MediaHub: confirm GoTrue decommission plan for non-admins
 -
- ▼
3. Backend: CognitoStrategy + auth controller (remove GoTrue proxy)
 -
- ▼
4. Frontend: Cognito login/OAuth on CHT domain only
 -
- ▼
5. Staging cutover – zero MediaHub auth URLs for end users
 -
- ▼
6. User migration (GoTrue sub → Cognito sub)
 -
- ▼
7. Production cutover + MediaHub GoTrue decommission for end users
 -
- ▼
8. Remove GOTRUE_JWT_SECRET, SUPABASE_* from CHT secrets
 -
- ▼
9. Expand CHT catalog APIs (API key sync from MediaHub – unchanged auth model)

7. Risks and Mitigations

Risk	Severity	Mitigation
MediaHub decommissions GoTrue before Cognito ready	Critical	Joint cutover date; staged staging first
User migration breaks authId linkage	High	Migration table; dry-run on staging
MFA enrollment friction for HCPs	High	Grace period; clear UX; support runbook
MediaHub API key revoked during auth migration	High	Explicit API key continuity in MediaHub spec
OAuth misconfiguration on Cognito	High	Redirect URL matrix per environment
Existing users locked out	High	Parallel JWT window or forced reset comms
Admin loses MediaHub access	Medium	Admin-only GoTrue retained on MediaHub side
Low auth test coverage	Medium	Integration tests before prod cutover

8. Success Criteria

Migration is complete when:

1. **CHT owns IdP** — Amazon Cognito with TOTP MFA in all environments.
 2. **KOL, HCP, and industry users** authenticate only through CHT — no MediaHub GoTrue, URLs, or auth user records.
 3. **MediaHub has decommissioned GoTrue for all non-admin users** (confirmed by MediaHub team).
 4. **Only CHT admins** access MediaHub UI for content operations.
 5. **MediaHub API key integration remains** for server-to-server catalog and HCP sync — no user auth coupling.
 6. End-user catalog and account data is served through **CHT APIs** only.
 7. GOTRUE_JWT_SECRET, SUPABASE_URL, and SUPABASE_ANON_KEY are **removed** from CHT production secrets.
 8. Subprocessor register lists **Cognito** as auth provider; MediaHub as content/API subprocessor only.
 9. Auth integration tests pass; cutover and rollback runbooks are documented.
-

9. Recommendations

Do now

1. **Draft the Cognito Migration & MediaHub Auth Decommission Specification** (Section 5.2).
2. **Engage MediaHub team** on GoTrue decommission timeline for non-admin users.
3. **Assign owners** — Cognito migration is Phase 1; catalog API sync is Phase 2.

Do not do

1. **Keep end-user auth on MediaHub GoTrue** — this is explicitly out of scope for the target state.
2. **Expose MediaHub API keys or GoTrue client config** to end-user browsers.
3. **Cut over MediaHub GoTrue decommission without Cognito staging validation.**

Bottom line

CHT owns the IdP (Cognito + MFA). MediaHub decommissions GoTrue for everyone except admins. End users never touch MediaHub. Integration stays on API key only. The next step is the signed-off Cognito migration and MediaHub auth decommission specification.

10. Appendix

A. Key repository references

Document / path	Description
backend/src/auth/jwt.strategy.ts	JWKS pattern — adapt for Cognito
backend/src/auth/gotrue.strategy.ts	Remove/replace after cutover
backend/src/auth/auth.controller.ts	Rewire from GoTrue proxy to Cognito
backend/src/modules/catalog/mediahub.service.ts	API key catalog — keep
backend/src/modules/outbound-sync/mediahub-sync.service.ts	API key HCP sync — keep
frontend/src/lib/supabase-oauth.ts	Remove after Cognito OAuth on CHT

B. Environment variables (current → target)

Current (GoTrue)	Target (Cognito)	End-user browser?
SUPABASE_URL	— (removed)	No
SUPABASE_ANON_KEY	— (removed)	No
GOTRUE_JWT_SECRET	Cognito JWKS (derived from pool)	No
—	COGNITO_USER_POOL_ID	No
—	COGNITO_CLIENT_ID	Public client ID only if using SPA flow
—	COGNITO_REGION	No
MEDIAHUB_API_KEY	MEDIAHUB_API_KEY (unchanged)	Backend only
MEDIAHUB_BASE_URL	MEDIAHUB_BASE_URL (unchanged)	Backend only

C. Report revision history

Date	Change
June 3, 2026	Initial report — Cognito migration plan
June 3, 2026	Revised — retain GoTrue; user isolation (superseded)
June 3, 2026	Corrected — CHT owns IdP via Cognito; MediaHub decommissions GoTrue for non-admins; API key retained; admin-only MediaHub access